Emergency Training Simulator POC

Markdown documentation PDF copy

0006 Local POC security boundary

Source: docs/adr/0006-local-poc-security-boundary.md

Markdown stays editable. This PDF is the reading/share copy.

Boundary: this project is still a POC, not operational guidance.

0006 Local POC security boundary

Status

Accepted

Context

The project is still a local proof of concept. It does not have production users, real emergency data, real patient data, cloud deployment, or a real Unreal client yet.

Even so, the repo already accepts client-shaped messages over WebSocket and writes logs. That means it needs a clear security boundary before more features are added.

Decision

The backend is the source of truth.

Clients may send requested trainee actions, but the backend decides:

- current scenario state
- validation status
- warnings and errors
- end conditions
- log records
- replay/review output

The backend will also enforce small POC input guardrails:

- safe identifier characters
- safe scenario ID format
- safe action name format
- small JSON-shaped payloads
- no unexpected message fields
- ordered sequence numbers
- duplicate event rejection

Consequences

This makes the local POC less fragile and sets the right habit for future Unreal, sensing, and generated-asset work.

It does not make the system production-secure. Authentication, authorization, TLS, rate limiting, deployment security, and real data handling still belong to future slices.